

Controls and compliance checklist

Does Botium Toys currently have this control in place?

Controls assessment checklist

Yes	No	Control
☐	☒	Least Privilege
☐	☒	Disaster recovery plans
☐	☒	Password policies
☐	☒	Separation of duties
☒	☐	Firewall
☐	☒	Intrusion detection system (IDS)
☐	☒	Backups
☒	☐	Antivirus software
☐	☒	Manual monitoring, maintenance, and intervention for legacy systems
☐	☒	Encryption
☐	☒	Password management system
☒	☐	Locks (offices, storefront, warehouse)
☒	☐	Closed-circuit television (CCTV) surveillance
☒	☐	Fire detection/prevention (fire alarm, sprinkler system, etc.)

Does Botium Toys currently adhere to this compliance best practice?

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
☐	☒	Only authorized users have access to customers' credit card information.
☐	☒	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
☐	☒	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
☐	☒	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
☐	☒	E.U. customers' data is kept private/secured.
☒	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
☐	☒	Ensure data is properly classified and inventoried.
☒	☐	Enforce privacy policies, procedures, and processes to properly document and maintain data.

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
☐	☒	User access policies are established.

- | | | |
|--------------------------|-------------------------------------|--|
| ☐ | ☒ | Sensitive data (PII/SPII) is confidential/private. |
| ☐ | ☒ | Data integrity ensures the data is consistent, complete, accurate, and has been validated. |
| ☐ | ☒ | Data is available to individuals authorized to access it. |

Recommendations (optional): In this section, provide recommendations, related to controls and/or compliance needs, that your IT manager could communicate to stakeholders to reduce risks to assets and improve Botium Toys' security posture.

- **Implement encryption of all PII/SPII data stored internally [HIGH]**
This must be put in place as quickly as possible, in order to provide confidentiality, prevent external threats from stealing plaintext data, and improve compliance.
- **Institute least-privilege access controls for employees [HIGH]**
This must be put in place as quickly as possible, in order to prevent internal threats from stealing data and to improve compliance.
- **Improve password policies and management [HIGH]**
This must be put in place as quickly as possible, in order to increase employee productivity, prevent attackers from compromising employee accounts, and improve compliance.
- **Develop disaster-recovery plans and backups [HIGH]**
This must be put in place as quickly as possible, in order to ensure business continuity and to provide integrity and availability of systems in the case of emergencies.
- **Establish regular management policies for legacy systems [MEDIUM]**
This should be put in place quickly, in order to reduce risks and patch vulnerabilities associated with old versions of software and hardware.

- **Install an Intrusion Detection System [MEDIUM]**

This should be put in place quickly, in order to strengthen detection of threats to systems and data and to make the incident-response process more organized and efficient.

- **Institute security training for employees [MEDIUM]**

This should be put in place quickly, in order to increase security awareness and compliance across the business.